Content

History of Changes in documented informations 1

Policy Statement 2

Background 2

General Requirements 2

Privileged Accounts 3

Shared User Accounts 4

Vendor or Default User Accounts 4

Test Accounts 4

Contractors and Vendors 5

Access Control Requirements 5

Responsibilities 5

Compliance 6

History of Changes in documented informations

Date	Created by	ID	Version	Change
26.01.2020	Ante Malenica	IAM	1.0	Initial Version
20.07.2020	Hrvoje Kovačević	IAM	1.1	Update
01.03.2021	Ante Malenica	IAM	1.2	Update

Mindsmiths	Identity and Access Management			
	ID	IAM	**Author**	Ante Malenica
	Version	1.2	**Date**	01.03.2021.

1. Policy Statement

a. Protecting access to IT systems and applications is critical to maintain the integrity of the Mindsmiths technology and data and prevent unauthorised access to such resources.
b. Access to Mindsmiths systems must be restricted to only authorized users or processes, based on the principle of strict need to know and least privilege

2. Background

a. Access controls are necessary to ensure only authorized users can obtain access to a company's information and systems.
b. Access controls manage the admittance of users to system and network resources by granting users access only to the specific resources they require to complete their job related duties.

3. General Requirements

a. Mindsmiths will provide access privileges to technology (including networks, systems, applications, computers and mobile devices) based on the following principles:
    i. Need to know – users or resources will be granted access to systems that are necessary to fulfill their roles and responsibilities.
    ii. Least privilege – users or resources will be provided with the minimum privileges necessary to fulfill their roles and responsibilities.
b. Requests for users' accounts and access privileges must be formally documented and appropriately approved.
c. Requests for special accounts and privileges (such as vendor accounts, application and service accounts, system administration accounts, shared / generic accounts, test accounts and remote access) must be formally documented and approved by the system owner.
d. Application and service accounts must only be used by application components requiring authentication; access to the passwords must be restricted to authorized IT administrators or application developers only.
e. Where possible, Mindsmiths will set user accounts to automatically expire at a pre-set date.

More specifically,

i. When temporary access is required, such access will be removed immediately after the user has completed the task for which the access was granted.
ii. User accounts assigned to contractors will be set to expire according to the contract's expiry date.
iii. User accounts will be disabled after 1 month of inactivity..

f. Access rights will be immediately disabled or removed when the user is terminated or ceases to have a legitimate reason to access Mindsmiths systems.
g. A verification of the user's identity must be performed by the IT Director or designate before granting a new password.
h. Existing user accounts and access rights will be reviewed at least annually to detect inactive accounts and accounts with excessive privileges. Examples of accounts with excessive privileges include:
   i. An active account assigned to external contractors, vendors or employees that no longer work for the Mindsmiths.
   ii. An active account with access rights for which the user's role and responsibilities do not require access. For example, users that do not have authority or responsibility to approve expenses should not have access with approval permissions within a financial system.
   iii. System administrative rights or permissions (including permissions to change the security settings or performance settings of a system) granted to a user who is not an administrator.
   iv. Unknown active accounts.

4. Privileged Accounts

a. A nominative and individual privileged user account must be created for administrator accounts (such as "first_name.last_name"), instead of generic administrator account names.
b. Privileged user accounts can only be requested by managers or supervisors and must be appropriately approved
c. Shared admin or super user accounts are prohibited and name specific user accounts with admin rights should be used instead.
d. When it is not possible due to technical constraints shared admin or super user accounts should be properly controlled and tracked.

5. Shared User Accounts

a. Where possible, the use of specific network domain "security groups" should be used to share common access permissions across many users, instead of shared accounts.
b. Shared user accounts are only to be used on an exception basis with the appropriate approval. This includes general user accounts such as "guest" and "functional" accounts.
c. When shared accounts are required:
    i. Passwords will be stored and handled in accordance with the Password Policy.
    ii. The use of shared accounts will be monitored where possible, including the recording of the time of access, the reason for accessing the shared user account, and the individual accessing his account. When the shared user account has administrative privileges, such a procedure is mandatory and access to the monitoring logs must be protected and restricted.

6. Vendor or Default User Accounts

a. Where possible, all default user accounts will be disabled or changed. These accounts include "guest", "temp", "admin", "Administrator", and any other commonly known or used default accounts, as well as related default passwords used by vendors on "commercial off-the shelf" systems and applications

7. Test Accounts

a. Test accounts can only be created if they are justified by the relevant business area or project team and approved by the application owner, through a formal request to the IT Director
b. Test accounts must have an expiry date (maximum of 6 months). Maintaining test accounts beyond this date must be re-evaluated every 90 days and approved appropriately.
c. Test accounts will be disabled / deleted when they are no longer necessary

8. Contractors and Vendors

a. In accordance with the Information Security Policy, contracts with contractors / vendors will include specific requirements for the protection of data. In addition, contractor / vendor representatives will be required to sign a Non-disclosure Agreement ("NDA") prior to obtaining approval to access Mindsmiths systems and applications.
b. Mindsmiths will maintain a current list of external contractors or vendors having access to Mindsmiths systems.

9. Access Control Requirements

a. All users must use a unique ID to access Mindsmiths systems and applications. Passwords must be set in accordance with the Password Policy.
b. Alternative authentication mechanisms that do not rely on a unique ID and password must be formally approved.
c. Remote access to Mindsmiths systems and applications must use two-factor authentication where possible.
d. System and application sessions must automatically lock after 10 minutes of inactivity.

10. Responsibilities

a. Senior Responsible Owner (SRO) are responsible for ensuring that the requirements of this policy are implemented within any programme, projects, systems or services for which they are responsible. The SRO is responsible for ensuring that a robust checking regime is in place and complied with to ensure that legitimate user access is not abused. The SRO may delegate responsibility for the implementation of the policy but retains ultimate accountability for the policy and associated checking regime. Any non-compliance with this policy must be supported by a documented and evidence based risk decision accepted by the SRO.
b. Managers are responsible for ensuring that members of their team have the minimum levels of access to systems they need to perform their job. They must authorise the access rights for each individual team member and keep a record of the latest access permissions authorised. Managers should ensure that the access rights of people who have a change of duties or job roles or left the organisation are revoked immediately and

that any access tokens (smartcard/USB dongle) are recovered. All Managers should review the access levels of their people to ensure they are appropriate.

c. IT Support Teams are responsible for granting access to systems or use of Role Based Access Controls in accordance with the relevant procedures. IT Support Teams must evaluate and, if necessary, challenge authorised access to help identify any obvious anomalies in the access levels granted or requested.

d. Users must only use business systems for legitimate use as required by their job and in accordance with the procedures for those systems.

11. Compliance

a. Compliance against this policy will be assessed regularly. Any violation of this policy must be investigated and may result in disciplinary action being taken